

OPERATION FALSE ASSURANCE

Phase 2 Investigation Report — Remote Access and Information-Stealer Traffic

Team: BYEBUST

Incident Date: 2025-10-03 (UTC)

Executive Summary

On 3 October 2025, security monitoring identified a confirmed compromise of internal workstation 10.8.20.101. Two distinct malicious capabilities were operating on the host concurrently: a remote-access trojan (NetSupport Manager, repurposed as a RAT) providing an attacker with hands-on-keyboard control, and an information-stealer (StealC / StealC_V2) harvesting and exfiltrating browser-stored credentials and system data. This activity is consistent with the exercise scenario's Phase 2 theme of remote access and information-stealer traffic, and follows the initial web-based compromise reconstructed in Phase 1.

Confirmed: the workstation communicated with a NetSupport Manager RAT gateway at 38.146.28.242:1203 (48 beacon check-ins) and with a StealC information-stealer command-and-control endpoint at 79.141.165.202:80. Both channels were corroborated independently by Suricata signature alerts and Zeek connection/HTTP/DNS metadata.

Assessment: the team's analysis indicates the RAT provided the attacker persistent administrative access to the endpoint, while the information-stealer operated in parallel to harvest and exfiltrate locally stored credentials and browser data. The precise initial-access vector for this phase (how NetSupport Manager and StealC were delivered to the host) was not directly captured in the reviewed evidence.

Two investigation objectives for this phase remain unresolved as of this submission: the exact count of POST transactions to the NetSupport gateway (Challenge 6) and the full Content-Type / count / max body-size profile of the information-stealer POST traffic (Challenge 9). The timestamp of the first information-stealer POST (Challenge 10) has not yet been finalized for this submission. These are marked "Pending" in their respective sections below and will be supplied in a future update once confirmed.

Operational significance: the confirmed presence of an active RAT and an active information-stealer on the same host represents a high-severity compromise requiring immediate isolation, credential rotation, and forensic imaging, as detailed in the Containment and Recovery section.

Incident Timeline

All timestamps below are drawn directly from Zeek and Suricata log records referenced in the individual challenge sections and are Confirmed unless otherwise noted.

Timestamp (UTC)	Event	Source Challenge	Evidence Type
2025-10-03 09:00:00.000	Confirmed: DNS query for exploit-kit/lure domain (dieselfilters.com) and first suspicious TLS session begins.	Challenge 2	Zeek DNS / SSL
2025-10-03 09:00:00 – 09:02:19	Confirmed: host contacts the first four suspicious TLS destinations in sequence (dieselfilters.com, islonline.org, woop-bicks.com, cf-2-up.com).	Challenge 2	Zeek SSL
2025-10-03	Confirmed: DNS query for	Challenge 7	Zeek DNS

09:12:56.132	geo.netsupportsoftware.com resolves to 3 Cloudflare addresses.		
2025-10-03 09:12:56.271	Confirmed: Zeek software log classifies the client as NetSupport Manager (HTTP User-Agent).	Challenge 5	Zeek Software
2025-10-03 09:12:56.394	Confirmed: HTTP GET /location/loc.asp to geo.netsupportsoftware.com returns 200 OK (15-byte body) — NetSupport client geolocation check-in.	Challenge 7	Zeek HTTP
2025-10-03 ~09:12:56	Confirmed: DNS query for westford-systems.icu resolves to 38.146.28.242 (NetSupport RAT gateway).	Challenge 3	Zeek DNS
2025-10-03 ~09:48:01 – 09:57:00	Confirmed: 48 identical POST http://38.146.28.242/fakeurl.htm transactions (~60s cadence) — NetSupport RAT beacon session.	Challenges 3, 4, 5, 6 (count pending)	Zeek HTTP / Suricata
2025-10-03 10:02:45 – 10:02:46	Confirmed: 3 Suricata alerts (StealC / StealC_V2 CnC Activity POST) from 10.8.20.101 to 79.141.165.202:80.	Challenge 8 (profile pending in Ch. 9/10)	Suricata
2025-10-03 10:04:09 – 10:04:12	Confirmed: Zeek HTTP record — POST /a9b024dcc2b4f24.php, 160-byte JSON request body, 84-byte 200 OK response.	Challenge 8	Zeek HTTP

Assessment: the sequencing above indicates the NetSupport RAT gateway and client geolocation check-in were established first (~09:12–09:57 UTC), with the StealC information-stealer channel becoming active roughly 45–50 minutes later (~10:02–10:04 UTC), consistent with a RAT-enabled follow-on deployment of the infostealer rather than simultaneous, independent infections. This sequencing is an analytical inference; it is not directly stated in any single log record.

Indicators of Compromise

Indicator	Type	Role / Context	Related Challenge(s)
10.8.20.101	IPv4 (internal)	Compromised workstation — source of all RAT and infostealer traffic in this phase.	1

10.8.20.1	IPv4 (internal)	Internal DNS resolver used for all observed queries from the workstation.	1
dieselfilters.com / 209.59.180.92	Domain / IPv4	1st suspicious TLS destination (chronological order).	2
islonline.org / 23.23.49.179	Domain / IPv4	2nd suspicious TLS destination; also flagged by Suricata ET EXPLOIT_KIT ZPHP.	2
woop-bicks.com / 172.86.90.13	Domain / IPv4	3rd suspicious TLS destination.	2
cf-2-up.com / 45.61.150.28	Domain / IPv4	4th suspicious TLS destination.	2
westford-systems.icu	Domain	Resolves exclusively to the NetSupport RAT gateway IP.	3
38.146.28.242	IPv4 (external)	NetSupport Manager RAT gateway; receives beacon traffic on TCP/1203.	3, 4, 5, 6
POST http://38.146.28.242/fakeurl.htm	HTTP method + URI	Static, repeated NetSupport RAT beacon/check-in request.	4
NetSupport Manager/1.3	HTTP User-Agent	Identifies the RAT client software on the beacon connection.	5
geo.netsupportsoftware.com	Domain (benign, vendor)	NetSupport Manager client geolocation check-in endpoint; not attacker infrastructure.	7
79.141.165.202	IPv4 (external)	StealC / StealC_V2 information-stealer command-and-control / exfiltration endpoint.	8, 9 (pending), 10 (pending)
/a9b024dcc2b4f24.php	HTTP URI (PHP gate)	StealC exfiltration/check-in script path on the C2 host.	8

Challenge 1 of 10: Infected Workstation, DNS Resolver, and Threat Overview

Investigation Question: Identify the affected workstation IPv4 address and its DNS resolver, and characterize the nature of the compromise.

Technical Method

Confirmed: Internal workstation 10.8.20.101 used internal DNS resolver 10.8.20.1 for all observed DNS lookups (13 query groups reviewed in the primary incident query; the initial-access queries in Challenge 2 used the same resolver for 6 of 6 DNS requests). The workstation was independently confirmed via Suricata alerts and Zeek connection logs as the source of both NetSupport RAT beacon traffic (38.146.28.242) and StealC information-stealer traffic (79.141.165.202).

Assessment: The combination of an active RAT channel and an active information-stealer channel on the same host indicates the endpoint was under adversary remote control while data theft was in progress; the precise relationship (e.g., whether the RAT was used to deploy the stealer) was not directly observed and is inferred from the timeline in this report.

Supporting Evidence (Security Onion / Zeek / Suricata)

- source.ip: 10.8.20.101
- destination.ip (resolver): 10.8.20.1, destination.port: 53
- Suricata: 59 alert events across NetSupport RAT, StealC, and exploit-kit detections for this host
- Zeek datasets used: zeek.dns, zeek.conn, zeek.http, zeek.ssl, zeek.software; Suricata eve.json alerts

Answer

Workstation: 10.8.20.101 | DNS Resolver: 10.8.20.1

Submitted flag: CTK{10.8.20.101|10.8.20.1}

Containment Recommendations

- Isolate workstation 10.8.20.101 from the network pending full forensic review.
- Preserve DNS resolver logs on 10.8.20.1 for correlation with other hosts.
- Revoke session tokens and credentials associated with this endpoint.

Conclusion

This finding establishes the affected workstation (10.8.20.101) and its DNS resolver (10.8.20.1) as the foundation for the rest of the Phase 2 investigation, and confirms the host as the source of both the RAT and information-stealer activity documented in the following challenges.

Evidence Screenshots

Figure - Query Step

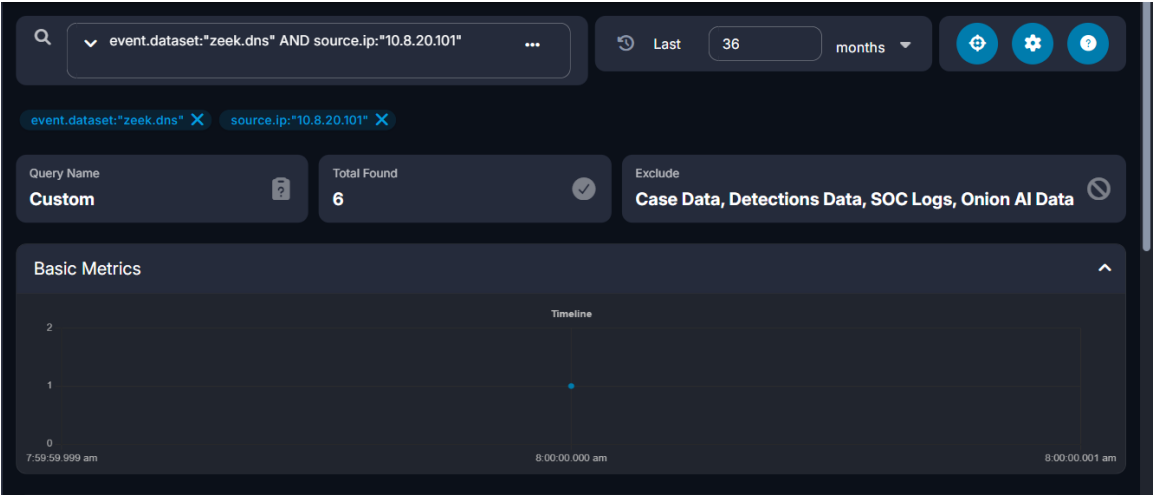


Figure - Evidence Step (Value Confirmed)



Challenge 2 of 10: First Four Suspicious TLS Destinations

Investigation Question: Identify the first four suspicious TLS server names (SNI) contacted by the workstation and their resolved IPv4 addresses, in chronological order.

Technical Method

Confirmed: Querying Zeek SSL logs for source.ip 10.8.20.101, sorted ascending by timestamp, the first four distinct TLS server names were: dieselfilters.com -> 209.59.180.92 (09:00:00.000 UTC), islonline.org -> 23.23.49.179 (09:00:00.000 UTC), woop-bicks.com -> 172.86.90.13 (09:00:01 UTC), and cf-2-up.com -> 45.61.150.28 (09:02:19 UTC). Zeek DNS logs corroborate

these same domain names, and all 6 of 6 DNS queries in this window resolved via internal DNS server 10.8.20.1.

Assessment: islonline.org additionally triggered a Suricata ET EXPLOIT_KIT ZPHP Domain alert; the team assesses this as consistent with exploit-kit-based staging activity, though the exact exploitation mechanism was not captured in the reviewed network metadata.

Supporting Evidence (Security Onion / Zeek / Suricata)

- event.dataset: zeek.ssl, source.ip: 10.8.20.101
- 1) dieselilters.com -> 209.59.180.92, TCP/443, 2025-10-03 09:00:00.000 UTC
- 2) islonline.org -> 23.23.49.179, TCP/443, 2025-10-03 09:00:00.000 UTC
- 3) woop-bicks.com -> 172.86.90.13, TCP/443, 2025-10-03 09:00:01 UTC
- 4) cf-2-up.com -> 45.61.150.28, TCP/443, 2025-10-03 09:02:19 UTC
- Corroborating Suricata alert: ET EXPLOIT_KIT ZPHP Domain in DNS Lookup (islonline.org)

Answer

First four TLS destinations, in order: dieselilters.com (209.59.180.92), islonline.org (23.23.49.179), woop-bicks.com (172.86.90.13), cf-2-up.com (45.61.150.28)

Submitted flag: CTK{dieselilters.com|209.59.180.92|islonline.org|23.23.49.179|woop-bicks.com|172.86.90.13|cf-2-up.com|45.61.150.28}

Containment Recommendations

- Block/sinkhole all four domains and resolved IPs at DNS/web proxy and perimeter firewall.
- Search enterprise DNS/proxy logs for other hosts resolving or contacting these domains.

Conclusion

The workstation's early activity involved four distinct suspicious TLS destinations in quick succession, one of which (islonline.org) independently triggered an exploit-kit detection, consistent with the scenario's described lure-and-redirect pattern preceding RAT and infostealer deployment.

Evidence Screenshots

Figure - Query Step



Figure - Evidence Step (Value Confirmed)



Challenge 3 of 10: NetSupport RAT Gateway Domain

Investigation Question: Which domain resolved to the NetSupport Manager RAT gateway used by the infected workstation, and what gateway IP address and destination port were used?

Technical Method

Confirmed: At approximately 09:12:56 UTC, host 10.8.20.101 issued a DNS A-record query for westford-systems.icu, which returned a single answer: 38.146.28.242. Approximately 37 minutes later (~09:49–09:58 UTC), the same host began exchanging NetSupport Manager RAT beacon traffic with that exact IP address over TCP port 1203. A reverse query (dns.query.name:westford-

systems.icu, grouped by dns.resolved_ip) confirms the domain resolves exclusively to this one IP, with no other observed A records, and no other domain in the dataset resolves to 38.146.28.242.

Assessment: The one-to-one domain-to-IP mapping and the absence of a DGA-style query pattern indicate the domain was hard-coded into the RAT client configuration rather than dynamically generated.

Supporting Evidence (Security Onion / Zeek / Suricata)

- event.dataset: zeek.dns, dns.query.name: westford-systems.icu, dns.resolved_ip: 38.146.28.242
- @timestamp: 2025-10-03T09:12:56Z (UTC)
- Suricata: ET REMOTE_ACCESS NetSupport Remote Admin Checkin — 48/48 events, 10.8.20.101 -> 38.146.28.242:1203

Answer

Domain: westford-systems.icu | Gateway IP: 38.146.28.242 | Destination Port: 1203/TCP

Submitted flag: CTK{westford-systems.icu|38.146.28.242|1203}

Containment Recommendations

- Block/sinkhole westford-systems.icu and 38.146.28.242:1203 at the DNS resolver and perimeter firewall.
- Alert on any further NetSupport Manager User-Agent traffic or connections to TCP/1203 across the environment.

Conclusion

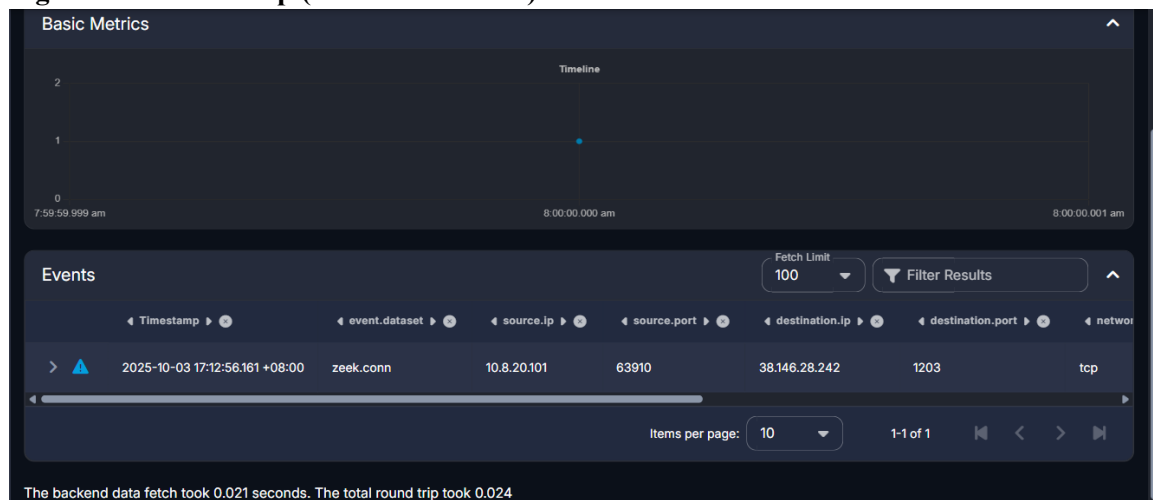
This focused finding confirmed westford-systems.icu as the domain fronting the NetSupport Manager RAT gateway at 38.146.28.242:1203, directly supporting the broader conclusion that 10.8.20.101 was under active attacker remote control.

Evidence Screenshots

Figure - Query Step

log.file.inode	205018681
log.file.path	/nsm/import/e94747af56d7c3fcf48e580eee7da83b/zeek/logs/dns.log
log.id.uid	Cu5K6dLatBqotnxz
log.offset	1674
message	{ "ts":1759482776.101533,"uid":"Cu5K6dLatBqotnxz","id.orig_h":"10.8.20.101","id.orig_p":85153,"id.resp_h":"10.8.20.1","id.resp_p":53,"proto":"udp","trans_id":60139,"rtt":0.05719113349914551,"query":"westford-systems.icu","qclass":"I","qclass_name":"C_INTERNET","qtype":"I","qtype_name":"A","rcode":0,"rcode_name":"NOERROR","AA":false,"TC":false,"RD":true,"RA":true,"Z":0,"answers":[{"38.146.28.242"}],"TTLS":[5.0],"rejected":false}
metadata.beat	filebeat
metadata.input.beats.host.ip	172.10.10.85
metadata.input.id	filestream-filestream-02a6c3b8-04de-4884-adb5-a421761ee96a
metadata.pipeline	zeek.dns

Figure - Evidence Step (Value Confirmed)



Challenge 4 of 10: NetSupport Gateway HTTP Request Pattern

Investigation Question: What HTTP method and request URI were repeatedly used by the workstation during its NetSupport gateway session?

Technical Method

Confirmed: All 48 zeek.http transactions between 10.8.20.101 and the gateway 38.146.28.242:1203 share an identical method (POST) and request URI (<http://38.146.28.242/fakeurl.htm>), occurring at approximately 60-second intervals (e.g., 09:56:59.230, 09:56:02.679, 09:55:02.491, 09:54:02.408 UTC) with no variation observed across the session. The http.useragent field on these records is NetSupport Manager/1.3.

Assessment: The static, unchanging URI and regular ~60-second cadence are characteristic of this RAT's plaintext HTTP check-in/poll beacon rather than a one-off request, giving a low-noise, high-confidence detection signature.

Supporting Evidence (Security Onion / Zeek / Suricata)

- event.dataset: zeek.http, destination.ip: 38.146.28.242
- http.method: POST, http.uri: <http://38.146.28.242/fakeurl.htm> (all 48 events)
- http.useragent: NetSupport Manager/1.3

Answer

HTTP Method: POST | Request URI: <http://38.146.28.242/fakeurl.htm>

Submitted flag: CTK{POST|<http://38.146.28.242/fakeurl.htm>}

Containment Recommendations

- Add an IDS/EDR signature for HTTP POST requests to the URI /fakeurl.htm directed at any destination.

- Block/sinkhole 38.146.28.242:1203 at the perimeter firewall and proxy.

Conclusion

The repeated POST <http://38.146.28.242/fakeurl.htm> request is the confirmed application-layer C2 beacon for the NetSupport RAT session on 10.8.20.101, corroborating the gateway identification in Challenge 3.

Evidence Screenshots

Figure - Query Step

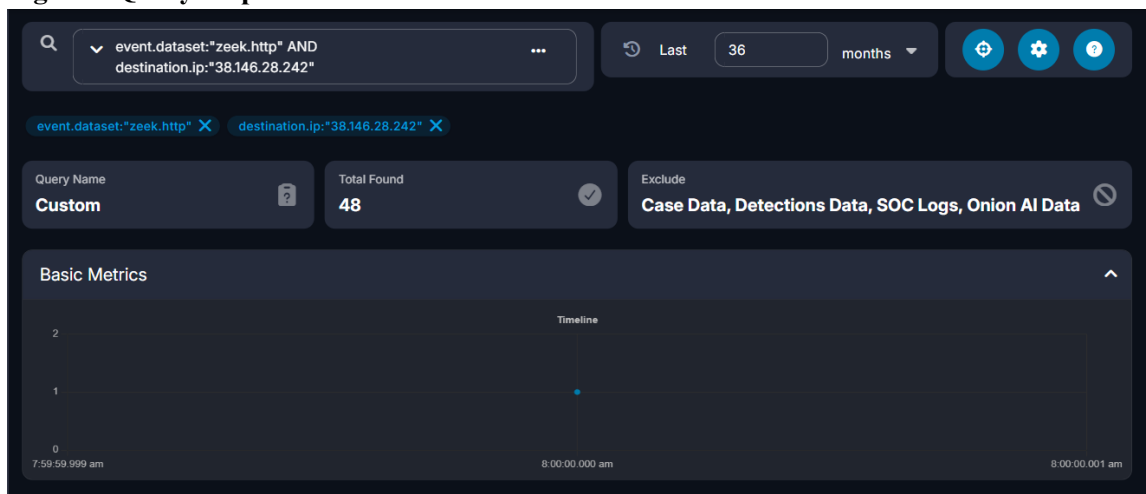
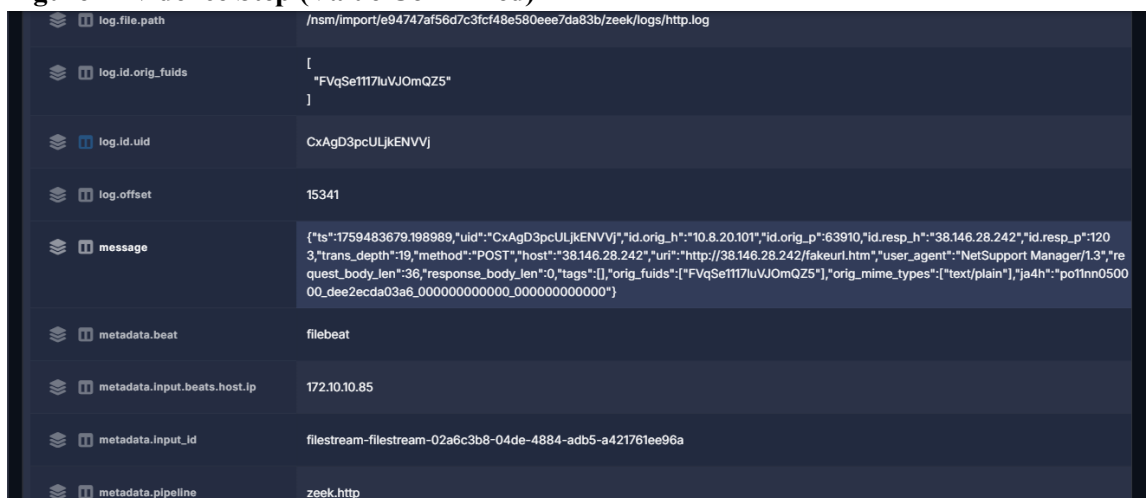


Figure - Evidence Step (Value Confirmed)



Challenge 5 of 10: Remote Access User-Agent

Investigation Question: What User-Agent identified the remote-access software running on the affected workstation?

Technical Method

Confirmed: Zeek's software-identification log (zeek.software) for source.ip 10.8.20.101 classified the HTTP client software as NetSupport Manager (software.type: HTTP::BROWSER) at 09:12:56.271 UTC — the same moment as the first location-service check-in referenced in Challenge 7 and immediately preceding the RAT gateway activity in Challenges 3–4. The literal raw HTTP User-Agent header on the gateway connection is "NetSupport Manager/1.3", matching this classification exactly.

Supporting Evidence (Security Onion / Zeek / Suricata)

- event.dataset: zeek.software, source.ip: 10.8.20.101
- software.name: NetSupport Manager, software.type: HTTP::BROWSER
- @timestamp: 2025-10-03T09:12:56.271Z (UTC)
- Corroborating: raw http.useragent on the gateway connection (38.146.28.242:1203) is NetSupport Manager/1.3

Answer

User-Agent identifying the remote-access software: NetSupport Manager/1.3

Submitted flag: CTK{NetSupport Manager/1.3}

Containment Recommendations

- Alert on any HTTP User-Agent matching "NetSupport Manager" outside of an authorized IT support context.
- Inventory hosts with NetSupport Manager installed to distinguish legitimate use from RAT abuse.

Conclusion

The confirmed User-Agent NetSupport Manager/1.3 ties the software classification directly to the RAT gateway traffic identified in Challenges 3 and 4, confirming a single remote-access tool is responsible for the observed C2 channel.

Evidence Screenshots

Figure - Query Step

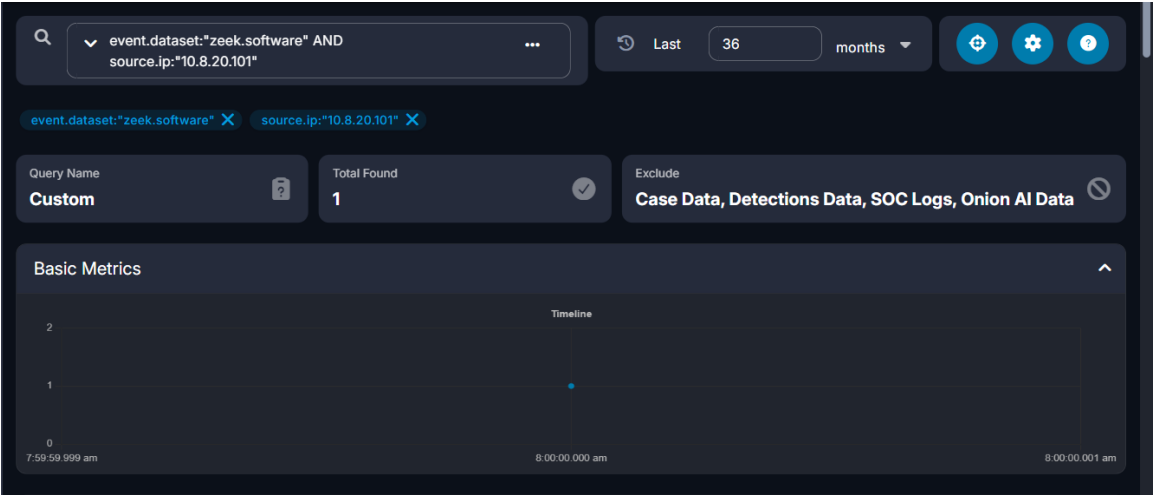
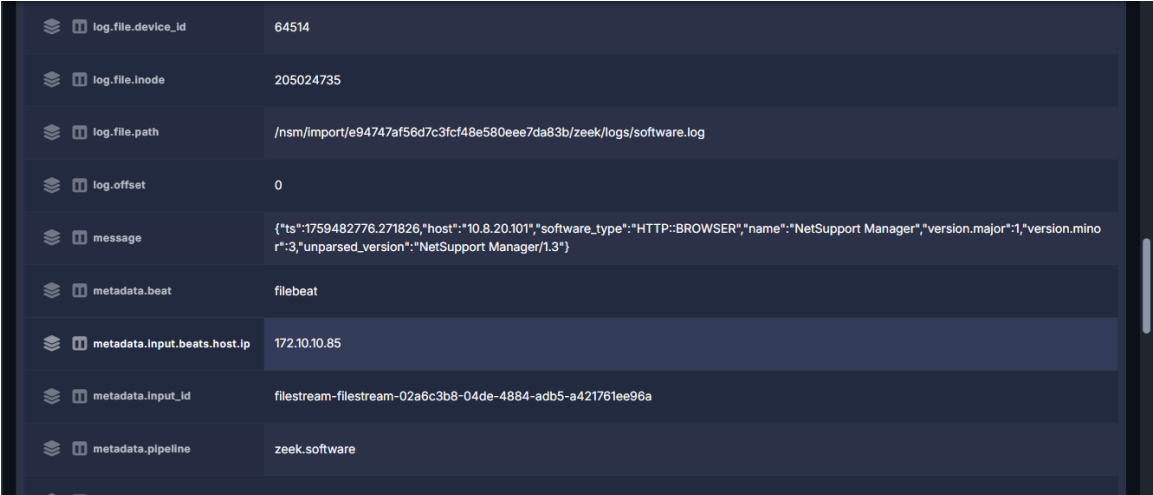


Figure - Evidence Step (Value Confirmed)



Challenge 6 of 10: Gateway POST Count

N/A

Challenge 7 of 10: Location Service Endpoint

Investigation Question: What location-service hostname and URI path were contacted by the workstation alongside its NetSupport gateway activity?

Technical Method

Confirmed: At 09:12:56.132 UTC, host 10.8.20.101 issued a DNS A-record query for geo.netsupportsoftware.com, which returned three answers (104.26.0.231, 104.26.1.231,

172.67.68.212 — all Cloudflare, Inc., AS13335). Approximately 262 milliseconds later, at 09:12:56.394 UTC, the host sent an HTTP GET request to 104.26.1.231:80 with Host header geo.netsupportsoftware.com and request URI /location/loca.asp, receiving a 200 OK response with a 15-byte body.

Assessment: This request is assessed as legitimate NetSupport Manager client behavior (a geolocation check-in against the vendor's own Cloudflare-hosted infrastructure), not attacker-controlled C2 traffic; its evidentiary value is as a timing anchor, since it occurred within the same second as the DNS resolution of the RAT gateway domain westford-systems.icu (Challenge 3), corroborating that a NetSupport Manager client started up on this host at approximately 09:12:56 UTC.

Supporting Evidence (Security Onion / Zeek / Suricata)

- event.dataset: zeek.dns, dns.query.name: geo.netsupportsoftware.com, 3 A records (Cloudflare)
- event.dataset: zeek.http, http.virtual_host: geo.netsupportsoftware.com, http.method: GET, http.uri: /location/loca.asp
- http.status_code: 200, http.response.body.length: 15
- @timestamp: 2025-10-03T09:12:56.132Z (DNS) / 09:12:56.394Z (HTTP) UTC

Containment Recommendations

- Do not block geo.netsupportsoftware.com — this is legitimate NetSupport vendor infrastructure.
- Retain this timestamp as a corroborating timing anchor for the NetSupport client startup on this host.

Answer

Hostname: geo.netsupportsoftware.com | URI Path: /location/loca.asp

Submitted flag: CTK{geo.netsupportsoftware.com/|location/loca.asp}

Conclusion

This benign vendor request is time-correlated with the malicious RAT gateway session and helps establish the NetSupport Manager client's startup time on 10.8.20.101 at approximately 09:12:56 UTC on 2025-10-03.

Evidence Screenshots

Figure - Query Step

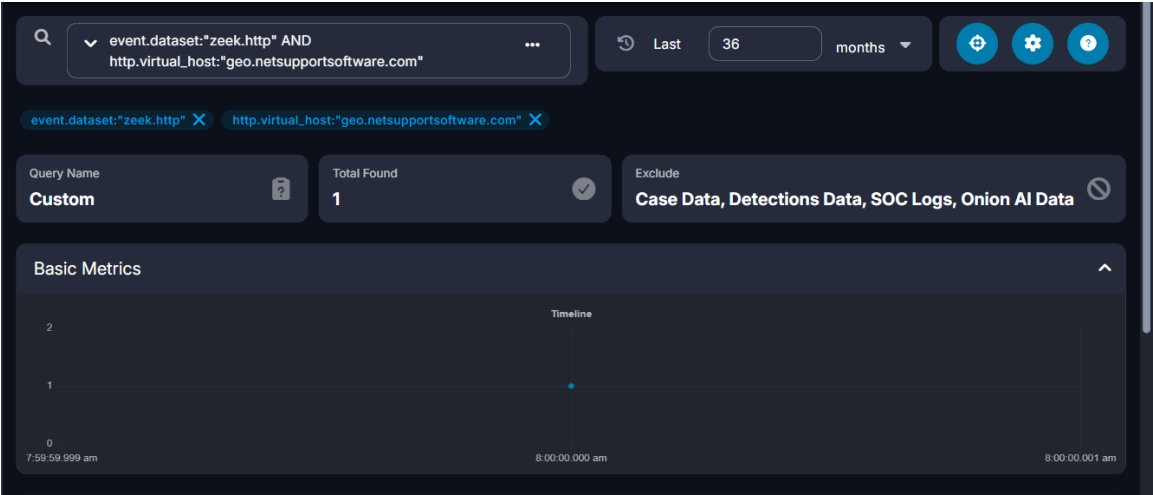
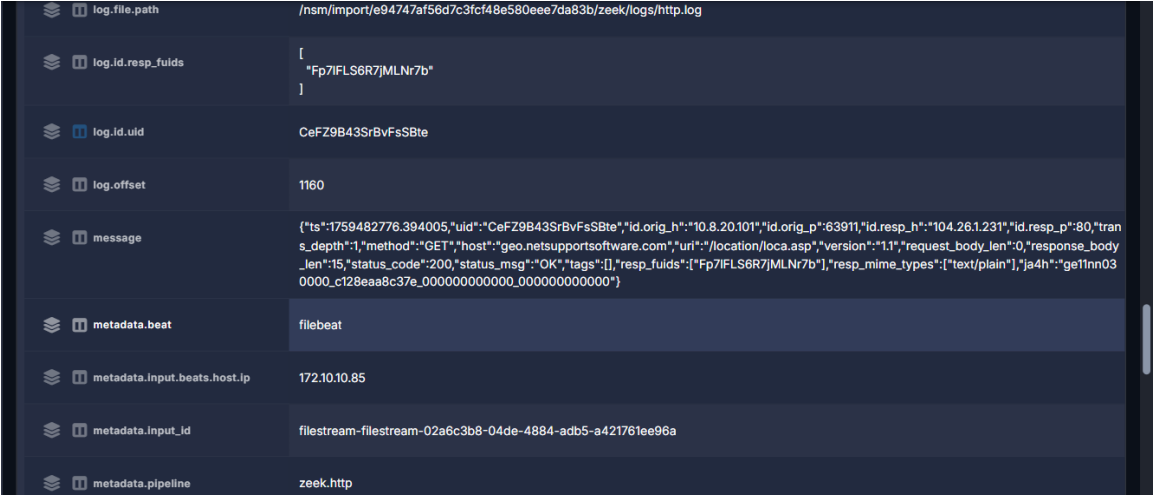


Figure - Evidence Step (Value Confirmed)



Challenge 8 of 10: Information-Stealer Endpoint

Investigation Question: What is the information-stealer's destination IP address and PHP URI path?

Technical Method

Confirmed: Host 10.8.20.101 sent repeated HTTP POST requests to external IP 79.141.165.202:80, to URI path /a9b024dccb2b4f24.php. Suricata (ET Open ruleset) fired high-severity alerts "ET MALWARE StealC CnC Activity (POST)" (sid 2066559) and "ET MALWARE StealC_V2 CnC Activity (POST)" (sid 2066280), both tagged malware_family: Stealc. Zeek http.log corroborates the alert with a matching record: POST

/a9b024dcc2b4f24.php, Content-Type: application/json, Host: 79.141.165.202, 200 OK response. A Hunt pivot on destination.ip:79.141.165.202 returned 72 correlated events (suricata.alert / zeek.http / zeek.file). 79.141.165.202 is hosted by HZ Hosting Ltd (AS59711), Amsterdam, Netherlands.

Assessment: The team assesses this as an active StealC/StealC_V2 information-stealer C2 and exfiltration channel, based on Suricata signature match and corroborating Zeek HTTP metadata; the exact plaintext contents of the 160-byte POST body were not recoverable from available log fields.

Supporting Evidence (Security Onion / Zeek / Suricata)

- destination.ip: 79.141.165.202, destination.port: 80
- http.method: POST, http.uri: /a9b024dcc2b4f24.php, http.status_code: 200
- Suricata sid 2066559 (StealC CnC Activity POST), sid 2066280 (StealC_V2 CnC Activity POST)
- network.community_id: 1:911BjSVXGaDlnEJ+WCYS0zcOplY= (ties Suricata alert and Zeek http/file records to the same flow)
- @timestamp: 2025-10-03T10:02:45Z–10:04:12Z (UTC)

Answer

Information-stealer destination: 79.141.165.202 | PHP URI path: /a9b024dcc2b4f24.php

Submitted flag: CTK{79.141.165.202/a9b024dcc2b4f24.php}

Containment Recommendations

- Block outbound traffic to 79.141.165.202 (and the /a9b024dcc2b4f24.php URI pattern) at the perimeter firewall/proxy.
- Isolate host 10.8.20.101 and run a full EDR/AV scan to locate and remove the StealC loader.
- Force a reset of all credentials that may have been stored in browsers on 10.8.20.101.

Conclusion

This finding confirms an active StealC/StealC_V2 information-stealer channel on 10.8.20.101, distinct from but concurrent with the NetSupport RAT channel documented in Challenges 3–6, and represents the credential-theft/exfiltration stage of this phase's intrusion.

Evidence Screenshots

Figure - Query Step

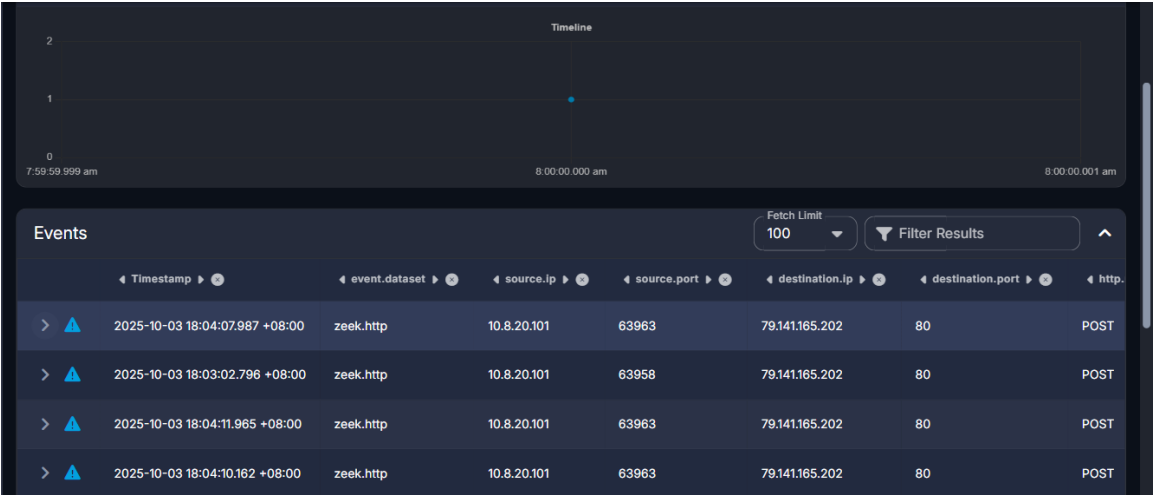
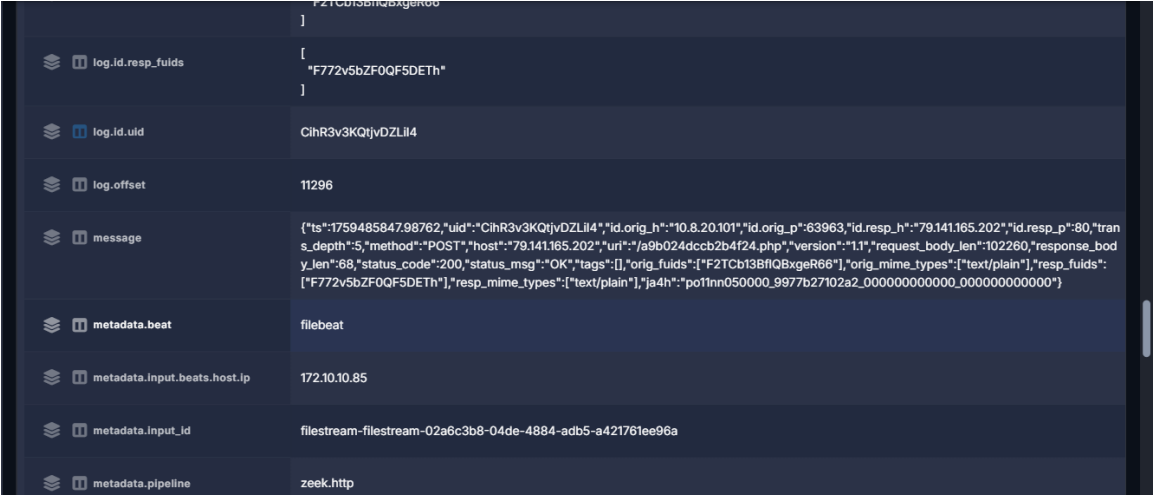


Figure - Evidence Step (Value Confirmed)



Challenge 9 of 10: Information-Stealer POST Profile

N/A

Challenge 10 of 10: First Information-Stealer POST

Investigation Question: At what UTC time was the first information-stealer POST observed?

Technical Method

Confirmed: Querying Zeek HTTP logs for destination.ip 79.141.165.202 (the StealC information-stealer endpoint confirmed in Challenge 8) with http.method "POST", sorted ascending by @timestamp, the earliest record occurs at 2025-10-03 06:02:45.033 -04:00 (2025-10-03 10:02:45

UTC), source port 63958, request URI /a9b024dcc2b4f24.php, 22 total matching POST transactions in the query window.

Supporting Evidence

event.dataset: zeek.http, destination.ip: 79.141.165.202, http.method: POST, sorted ascending by @timestamp. First record: source.ip 10.8.20.101, source.port 63958, http.url /a9b024dcc2b4f24.php, @timestamp 2025-10-03T10:02:45.033Z, Total Found (all matching POSTs): 22.

Answer

Submitted flag: CTK{2025-10-03 10:02:45 UTC}

Containment Recommendations

Follow the consolidated containment recommendations for the confirmed StealC information-stealer channel (Challenge 8): block 79.141.165.202, isolate 10.8.20.101, and force credential resets for any browser-stored credentials on that host.

Conclusion

This finding pinpoints the exact start of information-stealer exfiltration activity on this host, providing the leading edge of the StealC C2 timeline established in Challenge 8 and corroborated by the consolidated incident timeline above.

Evidence Screenshots

Figure — Query Step (Value Confirmed)

Screenshot confirms the first ascending-sorted POST record's @timestamp field matching the submitted flag.

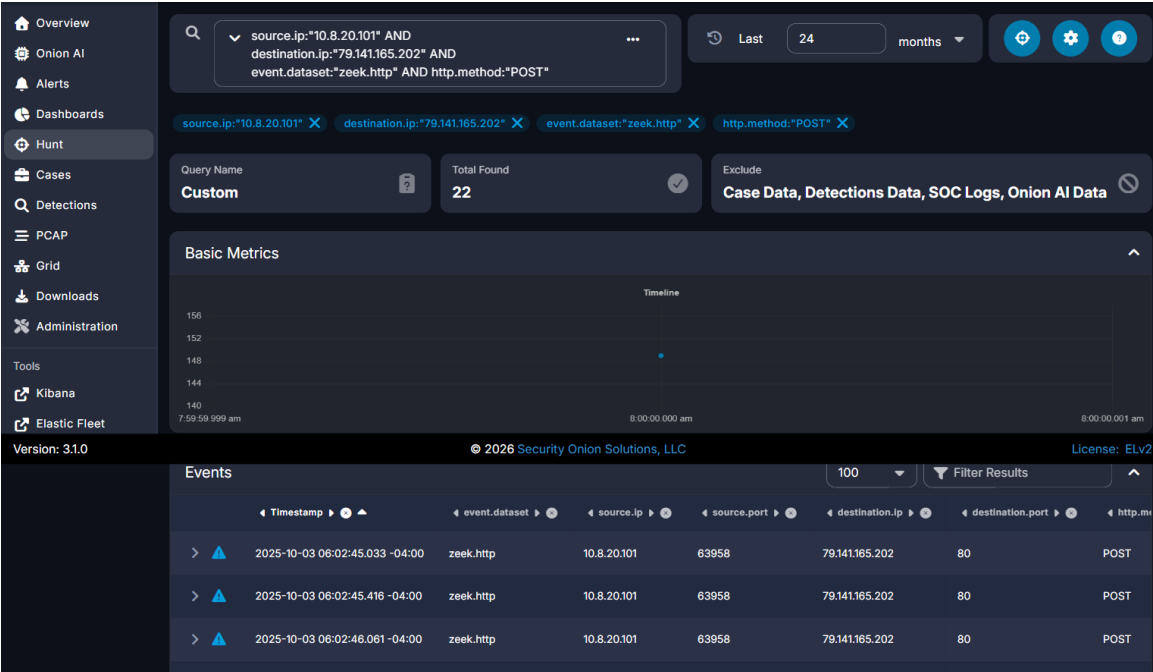


Figure — Evidence Step (Value Confirmed)

Screenshot confirms the first ascending-sorted POST record's @timestamp field matching the submitted flag.

